

CompliVibe

COMPANY POLICY MANUAL

The governance, security, privacy, and conduct standards that govern how we operate — held to the same bar we ask of our customers.

Confidential — Internal · Version 1.0
Approved by leadership · Reviewed at least annually

ABOUT THIS MANUAL

This manual sets out CompliVibe's company-wide policies. It applies to all employees, contractors, and third parties acting on the company's behalf. As a trust and compliance company, our own governance is not overhead — it is part of the product. We hold ourselves to the standard we sell.

How these policies work

- Each policy has a named owner and is reviewed at least annually or on material change.
- Compliance is mandatory. Breaches may result in disciplinary action, up to termination, and where relevant, legal action.
- Exceptions must be documented and approved in advance by the policy owner and leadership.
- Policies are versioned, dated, and acknowledged by every person on joining.

NOTE This manual is a governance framework. Jurisdiction-specific application (employment, tax, and sector law) should be confirmed with qualified legal counsel before enforcement.

CONTENTS

1. GOVERNANCE, ETHICS & CONDUCT

- 1.1 Code of Business Conduct & Ethics
- 1.2 Anti-Bribery & Anti-Corruption
- 1.3 Conflicts of Interest
- 1.4 Gifts & Hospitality
- 1.5 Whistleblower & Non-Retaliation
- 1.6 Sanctions, Export & Trade Compliance
- 1.7 Anti-Money-Laundering & CTF
- 1.8 Competition & Fair Dealing
- 1.9 Confidential & Inside Information

2. INFORMATION SECURITY

- 2.1 Information Security (ISMS)
- 2.2 Data Classification & Handling
- 2.3 Access Control & Identity
- 2.4 Acceptable Use
- 2.5 Authentication & Credentials
- 2.6 Encryption & Key Management
- 2.7 Endpoint & Device Security
- 2.8 Network & Cloud Security
- 2.9 Vulnerability & Patch Management
- 2.10 Secure Software Development
- 2.11 Change Management
- 2.12 Logging & Monitoring
- 2.13 Physical Security

3. DATA PROTECTION & PRIVACY

- 3.1 Data Protection & Privacy
- 3.2 Data Subject Rights
- 3.3 Data Retention & Disposal
- 3.4 Records Management
- 3.5 Cross-Border Transfers
- 3.6 Customer Data & Benchmarking

4. AI GOVERNANCE

- 4.1 Responsible AI
- 4.2 AI Risk & Model Oversight
- 4.3 AI Data & Training Governance
- 4.4 Human Oversight & Transparency

5. RESILIENCE & THIRD PARTIES

- 5.1 Incident Response & Breach Notification
- 5.2 Business Continuity & Disaster Recovery
- 5.3 Vendor & Third-Party Risk
- 5.4 Sub-Processor Management

6. PEOPLE & WORKPLACE

- 6.1 Equal Opportunity & Non-Discrimination
- 6.2 Anti-Harassment & Respect
- 6.3 Health, Safety & Wellbeing
- 6.4 Remote & Hybrid Work
- 6.5 Onboarding & Offboarding
- 6.6 Security Awareness & Training
- 6.7 Disciplinary & Grievance

7. CUSTOMER, LEGAL & COMPLIANCE PROGRAM

- 7.1 Regulatory Compliance & Framework Mapping
- 7.2 Risk Management
- 7.3 Customer Terms of Service
- 7.4 Customer Privacy Policy
- 7.5 DPA & Service-Level Agreement
- 7.6 Responsible Disclosure
- 7.7 Customer Acceptable Use
- 7.8 Trust Centre & Transparency

8. POLICY GOVERNANCE

- 8.1 Policy Management
- 8.2 Approvals & Version Control

1 GOVERNANCE, ETHICS & CONDUCT

Owner: Chief Executive / Legal

1.1 Code of Business Conduct & Ethics

The baseline of lawful, ethical, professional behaviour expected of everyone.

- Act with integrity and honesty in every dealing.
 - Comply with all applicable laws and company policies.
 - Treat colleagues, customers, and partners with respect.
 - Protect company and customer assets and reputation.
 - Raise concerns openly, without fear of reprisal.
-

1.2 Anti-Bribery & Anti-Corruption

Zero tolerance for bribery and corruption in any form.

- Never offer, give, or accept anything of value to improperly influence a decision.
 - No facilitation payments.
 - Record all payments accurately and transparently.
 - Conduct due diligence on third parties acting for us.
-

1.3 Conflicts of Interest

Personal interests must never compromise company duties.

- Disclose actual or potential conflicts promptly.
 - Recuse yourself from affected decisions.
 - Outside activities and investments must not impair objectivity.
-

1.4 Gifts & Hospitality

Keep gifts and hospitality modest, transparent, and infrequent.

- Never give or accept cash or cash equivalents.
 - Nothing intended to influence a business decision.
 - Record anything above the declared threshold.
-

1.5 Whistleblower & Non-Retaliation

Safe, confidential channels to raise concerns.

- Report suspected wrongdoing through the designated channel.
 - Good-faith reports are protected; retaliation is prohibited.
 - Concerns are investigated promptly and fairly.
-

1.6 Sanctions, Export & Trade Compliance

We do not deal with prohibited parties or jurisdictions.

- Screen customers and partners against applicable sanctions lists.
 - Comply with export controls on technology and data.
 - Escalate any potential match or restriction.
-

1.7 Anti-Money-Laundering & CTF

Prevent the company being used to launder funds or finance crime.

- Apply know-your-customer checks where applicable.
 - Monitor for and report suspicious activity.
 - Maintain accurate supporting records.
-

1.8 Competition & Fair Dealing

Compete vigorously but lawfully.

- No price-fixing, market allocation, or anti-competitive agreements.
 - Exercise care in any communication with competitors.
-

- Deal fairly with customers, suppliers, and rivals.
-

1.9 Confidential & Inside Information

Protect confidential and material non-public information.

- Use confidential information only for authorised purposes.
- Do not disclose it without authorisation.
- Never trade, or enable trading, on inside information.

2 INFORMATION SECURITY

Owner: Head of Security / CISO

2.1 Information Security (ISMS)

A risk-based security programme protecting the confidentiality, integrity, and availability of information.

- Maintain an ISMS aligned to ISO 27001 / SOC 2.
 - Manage security risks through a documented, continuous process.
 - Assign clear security responsibilities across the company.
-

2.2 Data Classification & Handling

Protect data according to its sensitivity.

- Classify data as Public, Internal, Confidential, or Restricted.
 - Label, store, and share data per its classification.
 - Apply the strongest controls to customer and personal data.
-

2.3 Access Control & Identity

Access is granted on least-privilege, need-to-know terms.

- Role-based access; approvals required for elevation.
 - Multi-factor authentication for privileged and remote access.
 - Review access periodically; revoke on role change or exit.
-

2.4 Acceptable Use

Company systems are for legitimate business use.

- No illegal, insecure, or unauthorised use.
 - No unapproved software or data exfiltration.
 - Report lost devices or suspected compromise immediately.
-

2.5 Authentication & Credentials

Strong, protected credentials on every account.

- Unique strong credentials; use the approved password manager.
 - MFA mandatory where available.
 - Never share or reuse credentials.
-

2.6 Encryption & Key Management

Sensitive data is encrypted end to end.

- Encrypt data in transit and at rest with approved algorithms.
 - Protect, rotate, and control cryptographic keys.
 - No sensitive data stored or sent unencrypted.
-

2.7 Endpoint & Device Security

Every device accessing company data is managed and secured.

- Devices must be encrypted, patched, and screen-locked.
 - Remote-wipe capability required.
 - BYOD only where approved and enrolled in management.
-

2.8 Network & Cloud Security

Infrastructure is hardened and segmented by default.

- Secure configuration baselines and deny-by-default rules.
 - Network segmentation and least-exposure design.
 - Hardened, monitored cloud environments.
-

2.9 Vulnerability & Patch Management

Find and fix weaknesses before they are exploited.

- Regular scanning of systems and dependencies.
 - Risk-based remediation timelines.
 - Prompt patching of critical vulnerabilities.
-

2.10 Secure Software Development

Security is built into the product, not bolted on.

- Threat-informed design and mandatory code review.
 - Dependency and secrets scanning in the pipeline.
 - Testing and approval before release; separation of duties.
-

2.11 Change Management

Changes are controlled, tested, and reversible.

- Authorise, test, and document changes before deployment.
 - Maintain rollback plans.
 - Separate development from production.
-

2.12 Logging & Monitoring

We can see, detect, and reconstruct what happens.

- Log security-relevant events and protect the logs.
 - Monitor and alert on anomalies.
 - Retain logs per the retention schedule.
-

2.13 Physical Security

Protect facilities, equipment, and media.

- Control physical access to any company premises and hardware.
- Secure or destroy media at end of life.
- Apply equivalent care to home and remote workspaces.

3 DATA PROTECTION & PRIVACY

Owner: Data Protection Officer

3.1 Data Protection & Privacy

Personal data is handled lawfully, fairly, and transparently.

- Comply with GDPR, DPDP, and other applicable privacy laws.
 - Collect the minimum data needed, for a defined purpose.
 - Apply privacy by design and by default.
-

3.2 Data Subject Rights

Individuals can exercise their rights over their data.

- Honour access, rectification, erasure, portability, and objection.
 - Respond within legally required timeframes.
 - Verify identity before disclosing personal data.
-

3.3 Data Retention & Disposal

Keep data only as long as necessary.

- Retain data per the retention schedule or legal requirement.
 - Securely delete or anonymise at end of life.
 - No indefinite retention of personal data.
-

3.4 Records Management

Records are accurate, complete, and available.

- Maintain records per the retention schedule.
 - Protect record integrity and availability.
 - Dispose of records securely when due.
-

3.5 Cross-Border Transfers

Personal data crosses borders only with adequate safeguards.

- Use approved transfer mechanisms (adequacy / SCCs).
 - Assess and document transfer risk.
 - Restrict transfers to compliant destinations.
-

3.6 Customer Data & Benchmarking

Customer data is used strictly per contract and consent.

- Process customer data only for contracted purposes.
 - Benchmarking uses aggregated, anonymised data only.
 - Never expose one customer's data to another.
-

4 AI GOVERNANCE

Owner: Head of AI Governance

4.1 Responsible AI

Our own use of AI is accountable, fair, transparent, and safe.

- Maintain an inventory of AI systems in use.
 - Assess risk before deploying any AI system.
 - Assign accountable owners for each AI use case.
-

4.2 AI Risk & Model Oversight

AI risk is managed through its lifecycle.

- Risk-assess and document models (model cards).
 - Human review of high-impact AI outputs.
 - Monitor for drift, bias, and degradation.
-

4.3 AI Data & Training Governance

Data used with AI is lawful and protected.

- Establish a lawful basis and rights for AI data.
 - No confidential or personal data in unapproved AI tools.
 - Protect prompts, inputs, and outputs.
-

4.4 Human Oversight & Transparency

People stay meaningfully in control.

- Retain human oversight of consequential decisions.
- Disclose AI use where appropriate.
- Enable users to question and contest AI outputs.

5 RESILIENCE & THIRD PARTIES

Owner: Head of Security / Operations

5.1 Incident Response & Breach Notification

We detect, contain, and disclose incidents quickly.

- Maintain an incident response plan with clear roles.
 - Detect, contain, eradicate, and recover.
 - Notify affected parties and regulators within required timeframes.
 - Conduct a post-incident review.
-

5.2 Business Continuity & Disaster Recovery

The service survives disruption.

- Maintain BCP and DR plans with defined RTO/RPO.
 - Back up critical data regularly.
 - Test recovery on a scheduled basis.
-

5.3 Vendor & Third-Party Risk

Partners are held to our standards.

- Risk-assess and perform due diligence before onboarding.
 - Bind vendors to security and privacy obligations.
 - Monitor ongoing risk; offboard securely.
-

5.4 Sub-Processor Management

Sub-processors provide equivalent protection.

- Maintain a current sub-processor register.
- Ensure contractual protections flow down.
- Notify customers of changes per contract.

6 PEOPLE & WORKPLACE

Owner: Head of People

6.1 Equal Opportunity & Non-Discrimination

People are hired and treated on merit.

- No discrimination on any protected characteristic.
 - Fair, consistent people decisions.
 - An inclusive workplace for all.
-

6.2 Anti-Harassment & Respect

A safe, respectful workplace.

- Zero tolerance for harassment or bullying.
 - Safe, confidential reporting.
 - Prompt, proportionate action.
-

6.3 Health, Safety & Wellbeing

We protect people's safety and wellbeing.

- Provide a safe working environment.
 - Support wellbeing and reasonable accommodation.
 - Address risks to health and safety promptly.
-

6.4 Remote & Hybrid Work

Work anywhere, securely.

- Secure remote setups and protected connections.
 - Protect confidential information off-site.
 - Maintain conduct and availability standards.
-

6.5 Onboarding & Offboarding

Access follows the person's lifecycle.

- Provision least-privilege access on joining.
 - Complete security and policy training at onboarding.
 - Revoke all access and recover assets on exit.
-

6.6 Security Awareness & Training

Everyone is equipped to protect the company.

- Mandatory security and privacy training at onboarding and annually.
 - Ongoing phishing and threat awareness.
 - Role-specific training where needed.
-

6.7 Disciplinary & Grievance

Fair processes for breaches and concerns.

- Consistent, proportionate handling of policy breaches.
 - A clear route to raise grievances.
 - Due process and confidentiality.
-

7 CUSTOMER, LEGAL & COMPLIANCE PROGRAM

Owner: Legal / Compliance

7.1 Regulatory Compliance & Framework Mapping

We stay audit-ready against every obligation that applies.

- Identify applicable laws and frameworks.
- Map obligations to controls and evidence.
- Monitor regulatory change and update accordingly.

7.2 Risk Management

Risk is identified, owned, and managed.

- Maintain a risk register with owners.
- Assess, treat, and monitor risks.
- Report material risks to leadership.

7.3 Customer Terms of Service

Governs use of the platform. (Maintained by Legal.)

- Sets acceptable use, rights, warranties, and liability.
- Includes consent for anonymised benchmarking.
- Published and version-controlled.

7.4 Customer Privacy Policy

How we handle customer and end-user personal data. (Published.)

- Explains data collected, purposes, and rights.
- Kept current with our processing.
- Publicly available.

7.5 DPA & Service-Level Agreement

Contractual data and service commitments to customers.

- Data Processing Agreement for personal-data handling.
- SLA covering availability and support.
- Offered and honoured per contract.

7.6 Responsible Disclosure

A safe channel for reporting vulnerabilities.

- Published channel for external researchers.
- Safe harbour for good-faith research.
- Timely triage, fix, and acknowledgement.

7.7 Customer Acceptable Use

Defines permitted use of the platform.

- Prohibits unlawful or abusive use.
- Sets enforcement and suspension rights.
- Referenced in the Terms of Service.

7.8 Trust Centre & Transparency

We prove our posture publicly.

- Publish certifications, policies, and sub-processors.
- Provide a live status and security page.
- Report transparently on trust and incidents.

8 POLICY GOVERNANCE

Owner: Legal / Leadership

8.1 Policy Management

Every policy is owned, current, and enforced.

- Each policy has a named owner accountable for it.
 - Reviewed at least annually or on material change.
 - Exceptions require documented, pre-approved sign-off.
 - Breaches may lead to disciplinary or legal action.
-

8.2 Approvals & Version Control

Policies are controlled documents.

- Approved by leadership before taking effect.
- Versioned, dated, and centrally maintained.
- Communicated to all staff and acknowledged on joining.